

# Manual 08 - Ciclo de Vida de Riesgo de Proveedores y Terceros

---

## CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: c065e9ba7b7bbf37ff7c05de081a5864879e12ef | Idioma: es-419 | se mantienen los límites de riesgo de proveedores y de decisión humana.

**Límite de aseguramiento:** El gobierno de proveedores basado en riesgo reduce la incertidumbre, pero no elimina el riesgo de terceros o cuartas partes. La evidencia puede ser incompleta, desactualizada, controlada externamente o estar sujeta a cambios materiales. Los responsables humanos conservan las decisiones de aprobación, excepción, riesgo residual, renovación y salida.

## Rutas de implementación

## Manual 08 — Rutas de Implementación del Ciclo de Vida de Riesgo de Proveedores y Terceros

### Esencial

Úsalo para organizaciones más pequeñas o ecosistemas de proveedores acotados. Expectativas mínimas:

- inventario completo de proveedores/servicios y propietario responsable;
- clasificación de criticidad/riesgo inherente;
- debida diligencia basada en evidencia y proporcional al riesgo;
- decisión documentada de aprobar/condicionar/rechazar;
- cláusulas contractuales requeridas de seguridad/privacidad;
- controles de acceso y datos durante la incorporación;
- ruta de notificación de incidentes/cambios;
- actualización periódica de evidencia y reevaluación;
- desvinculación, revocación de acceso y evidencia de devolución/eliminación de datos.

### Estructurado

Úsalo para múltiples proveedores críticos, datos regulados, dependencia de nube/SaaS, tercerización material o proveedores de IA/modelos/API. Agregue:

- metodología estandarizada de niveles;
- requisitos de controles/evidencia por nivel;
- visibilidad de cuartas partes/subencargados;
- validación independiente de evidencia y seguimiento de excepciones;
- revisión de resiliencia/BCDR y riesgo de concentración;
- señales de monitoreo continuo y reevaluación basada en disparadores;
- planes formales de remediación y aceptación de riesgo;
- puertas de renovación vinculadas a asuntos no resueltos.

### Mejorado

Úsalo para infraestructura crítica, tercerización a escala empresarial, IA de alto impacto, dependencias sistémicas de nube, datos regulados/de gran volumen o riesgo concentrado de proveedores. Agregue:

- gobierno ejecutivo del riesgo y escenarios de concentración;
- arquitectura/flujo de datos/linaje de componentes;
- pruebas técnicas más profundas o aseguramiento independiente cuando se justifique;
- análisis de dependencias materiales de cuartas partes;
- protecciones contractuales de auditoría/acceso/incidente/salida;
- ejercicios conjuntos de incidentes y resiliencia;

- validación de contingencia/estrategia de salida;
- evidencia continua y monitoreo de cambios materiales.

## Ruta del ciclo de vida

### Gráfico de memoria del Manual 08 1

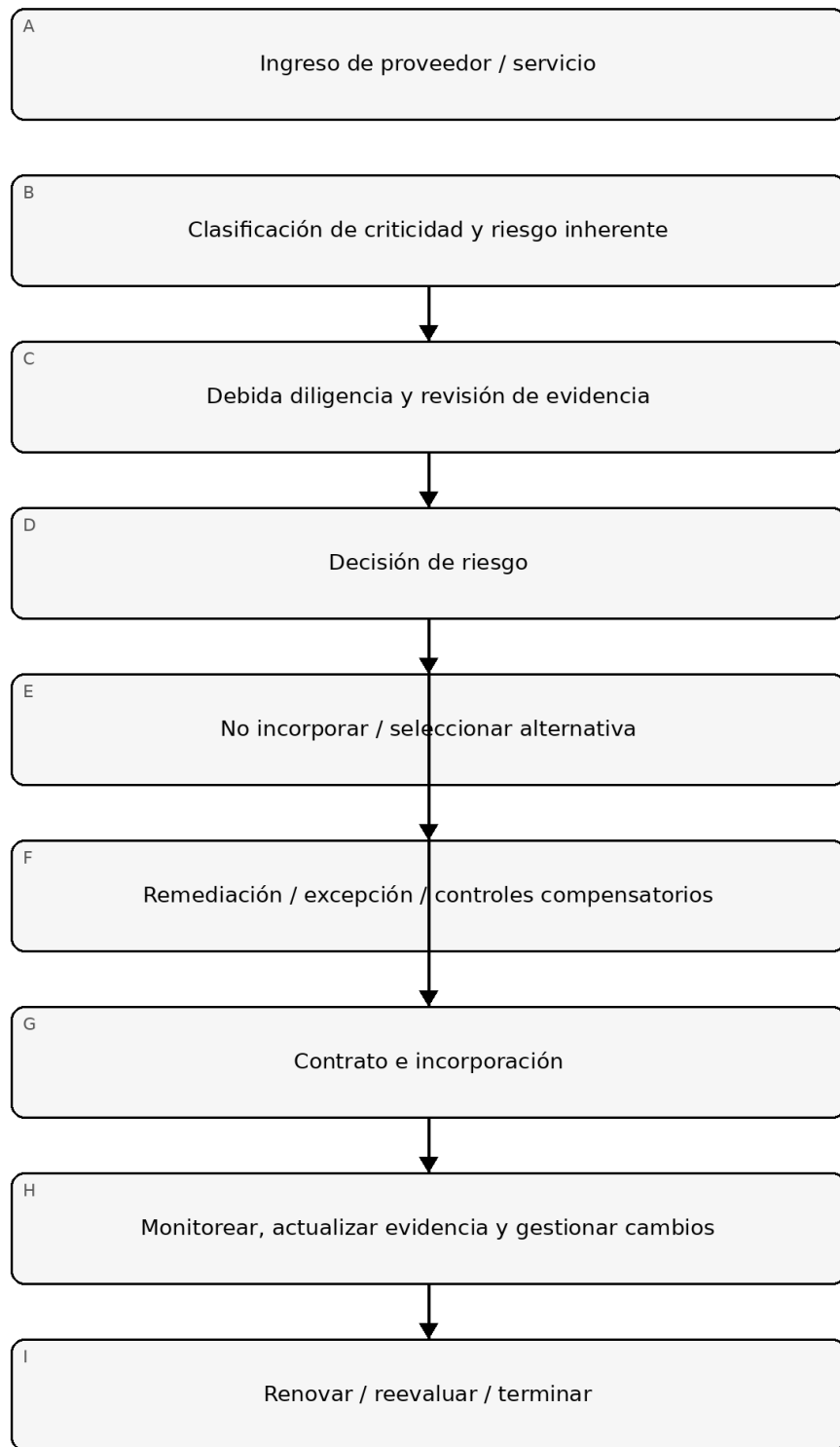


Figura 1. Gráfico de memoria de implementación

Explicación accesible: Cada proveedor comienza con clasificación y debida diligencia. Las decisiones pueden rechazar, aprobar condicionalmente o aprobar la relación. Los proveedores aprobados pasan a operación monitoreada y se reevaluarán en la renovación, ante cambios materiales o en la terminación.

## Cadena de evidencia y decisión

Gráfico de memoria del Manual 08 2

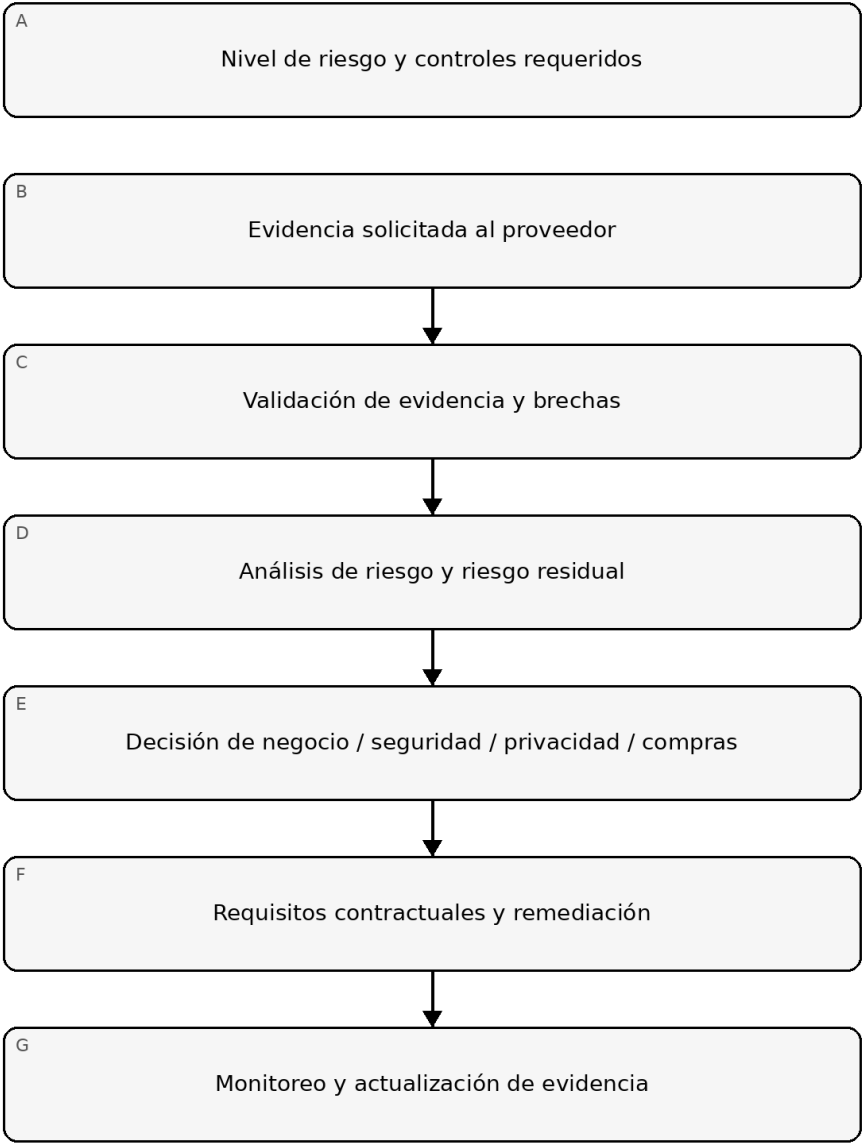
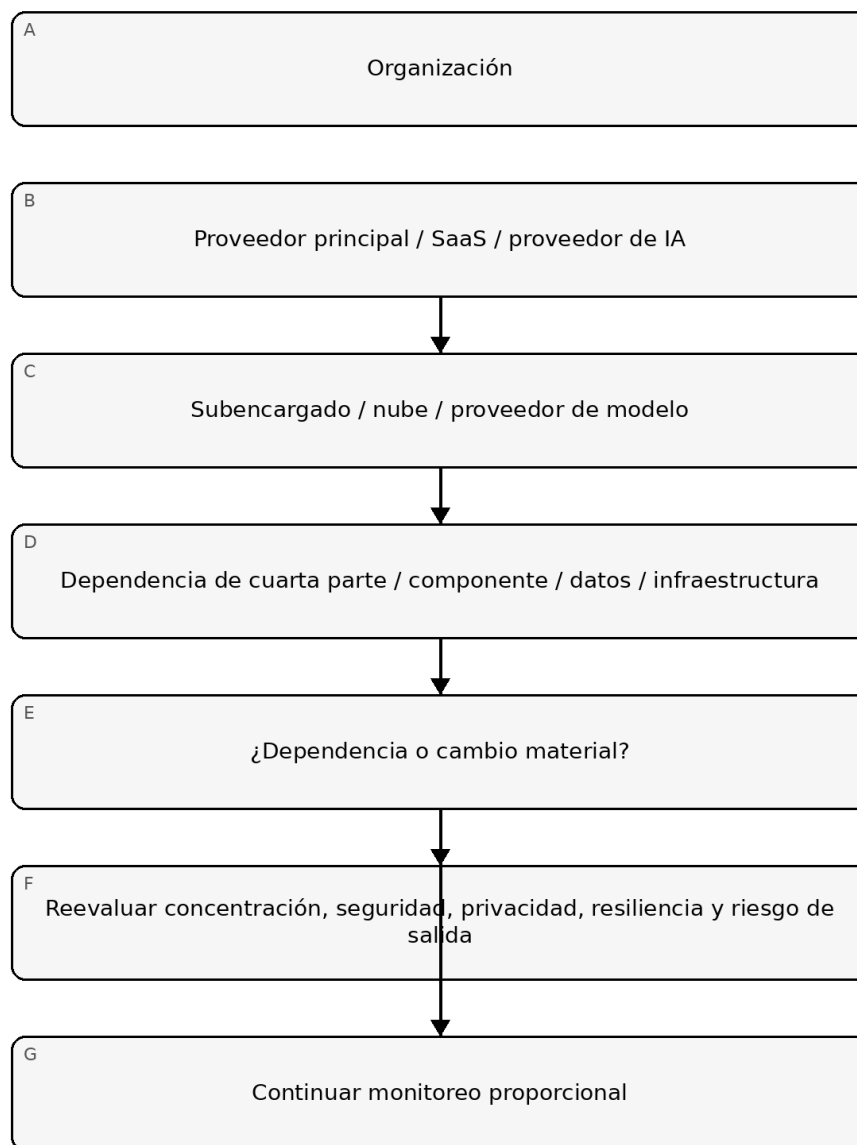


Figura 2. Gráfico de memoria de implementación

Explicación accesible: Las decisiones sobre proveedores se basan en controles requeridos, evidencia verificada, brechas identificadas y riesgo residual. La decisión resultante impulsa contratos, remediación y monitoreo continuo, en lugar de terminar al completar un cuestionario.

## Cadena de dependencias de cuartas partes e IA

**Gráfico de memoria del Manual 08 3**



**Figura 3. Gráfico de memoria de implementación**

Explicación accesible: El riesgo de proveedores puede extenderse más allá del proveedor contratado hacia subencargados, proveedores de nube/modelos y dependencias de cuartas partes. Las dependencias y cambios materiales activan una reevaluación en lugar de quedar ocultos detrás del contrato principal.

### Controles requeridos del ciclo de vida

1. Inventario y propiedad de proveedores/servicios.
2. Clasificación de criticidad, riesgo inherente, datos, acceso, geografía, regulación y concentración.
3. Debida diligencia de seguridad, privacidad, resiliencia, IA, aspectos financieros/operativos y cumplimiento según corresponda.
4. Validación de evidencia—incluidas certificaciones, informes, arquitectura, políticas, evidencia de pruebas, incidentes y remediación—no aseguramiento basado solo en cuestionarios.

5. Decisión de riesgo y excepción/aceptación de riesgo documentada.
6. Controles contractuales: uso de datos, confidencialidad, seguridad, aviso de incidentes, derechos de auditoría/evidencia, subencargados, resiliencia, uso de IA, retención, eliminación y salida.
7. Incorporación de identidades, conectividad, flujos de datos, claves/secretos y propiedad.
8. Monitoreo continuo, actualización de evidencia y disparadores de cambios materiales.
9. Gestión de incidentes, brechas, interrupciones de servicio, fallas de controles y remediación.
10. Puertas de renovación y reevaluación.
11. Desvinculación: revocación de acceso, devolución de activos/claves, devolución/eliminación de datos, retención y evidencia de transición/salida.

## Límite de aseguramiento

El gobierno de proveedores basado en riesgo reduce la incertidumbre, pero no puede eliminar el riesgo de terceros. El manual debe preservar las brechas conocidas, la dependencia de evidencia externa, las limitaciones de cuartas partes, el riesgo residual y las decisiones humanas responsables.

# Manual controlado de 32 capítulos

## Capítulo 01 — Objetivo y ciclo de vida de TPRM

La gestión de riesgos de terceros debe gobernar todo el ciclo de la relación: ingreso, clasificación, debida diligencia, decisión de riesgo, contratación, incorporación, monitoreo, gestión de incidentes y cambios, reevaluación y salida.

El proceso debe aplicarse de forma proporcional según aquello a lo que el proveedor puede acceder, influir, procesar, alojar, operar o interrumpir.

## Capítulo 02 — Inventario de proveedores y responsables

Mantenga un inventario controlado de proveedores, prestadores de servicios, subencargados, proveedores de IA/modelos, proveedores de datos, API, servicios de alojamiento y otras dependencias externas relevantes.

Cada registro debe identificar responsable de negocio, servicio, datos tratados, dependencias de sistemas, contrato, criticidad, geografía cuando corresponda, exposición a cuartas partes, fecha de renovación, nivel de monitoreo y requisitos de salida.

## Capítulo 03 — Criticidad y riesgo inherente

La criticidad pregunta qué ocurre si el proveedor falla; el riesgo inherente pregunta qué exposición existe antes de considerar controles. Están relacionados, pero no son lo mismo.

Los factores pueden incluir acceso a datos sensibles, conectividad privilegiada, acceso a producción, dependencia operativa, concentración, posibilidad de sustitución, impacto financiero, exposición regulatoria, autonomía de IA, dependencia de modelos o datos y consecuencias para la continuidad del negocio.

## Capítulo 04 — Planificación de la debida diligencia

La debida diligencia debe basarse en evidencia y ser proporcional. El plan de revisión debe identificar las preguntas que deben resolverse, la evidencia necesaria, los revisores y los umbrales de aceptación.

La evidencia posible incluye políticas, informes independientes, certificaciones, información de arquitectura, resultados de pruebas, historial de incidentes, evidencia de resiliencia, documentación de privacidad, compromisos contractuales, información financiera y entrevistas dirigidas.

Un cuestionario por sí solo no constituye aseguramiento para un proveedor material.

## Capítulo 05 — Revisión de seguridad, privacidad y resiliencia

La revisión debe determinar si los controles del proveedor son apropiados para el servicio y la exposición. Seguridad, privacidad y resiliencia deben evaluarse como disciplinas conectadas y no como cuestionarios aislados.

La revisión debe abordar identidad, acceso, protección de datos, registros, gestión de vulnerabilidades, respuesta a incidentes, capacidad de recuperación, subcontratación, ubicación, retención, eliminación y continuidad del servicio cuando corresponda.

## Capítulo 06 — Proveedores de IA y dependencias de modelos/componentes

La revisión de proveedores de IA debe identificar proveedores de modelos, inferencia alojada, servicios de ajuste fino, proveedores de datos, servicios de seguridad, fuentes de recuperación, proveedores de agentes/herramientas y otros componentes de IA.

Las preguntas clave incluyen uso de datos, comportamiento de entrenamiento o retención, notificación de cambios de modelo/versión, límites de seguridad, controles de contenido y abuso, disponibilidad del servicio, términos de propiedad intelectual, evidencia de auditoría, notificación de incidentes y opciones de salida.

## Capítulo 07 — Decisión de riesgo y excepciones

Todo resultado material de debida diligencia debe producir una decisión: aprobar, aprobar condicionalmente, exigir remediación, restringir alcance, aplazar o rechazar.

Las excepciones deben registrar el requisito incumplido, justificación de negocio, control compensatorio, responsable, riesgo residual, aprobador, fecha de vencimiento y requisito de monitoreo. Deben evitarse las excepciones permanentes sin revisión periódica.

## Capítulo 08 — Puerta de incorporación con cierre por defecto

La incorporación debe bloquearse cuando la debida diligencia requerida esté incompleta, falte evidencia crítica, los hallazgos de alto riesgo carezcan de tratamiento aprobado, los términos contractuales obligatorios estén sin resolver o falte una aprobación humana obligatoria.

Un proveedor no debe representarse como “aprobado” solo porque terminó el proceso de compras. Un cambio material posterior —por ejemplo, un nuevo subencargado, modelo de servicio, uso de datos, componente de IA, ubicación de alojamiento o arquitectura de seguridad— puede reabrir la revisión afectada.

## Capítulo 09 — Calidad de la evidencia

La evidencia debe evaluarse por relevancia, vigencia, alcance, independencia y aplicabilidad al servicio real. Un documento puede ser válido y aun así resultar irrelevante si cubre otro producto, entorno, entidad o periodo.

## Capítulo 10 — Requisitos de control contractual

Los riesgos materiales identificados durante la debida diligencia deben reflejarse en términos contractuales cuando corresponda. Los temas pueden incluir obligaciones de seguridad, privacidad/tratamiento de datos, derechos de auditoría, notificación de incidentes, subcontratación, niveles de servicio, resiliencia, notificación de cambios, devolución/eliminación de datos y apoyo a la salida.

## Capítulo 11 — Derecho de auditoría y acceso al aseguramiento

Las cláusulas de derecho de auditoría deben poder usarse en la práctica. La organización debe comprender si el aseguramiento se proporcionará mediante informes, certificaciones, paquetes de evidencia, entrevistas, revisiones dirigidas, trabajo en sitio u otros mecanismos.

## Capítulo 12 — Subencargados y cuartas partes

Los subencargados y cuartas partes materiales deben ser suficientemente visibles para comprender concentración, tratamiento de datos, dependencia operativa y riesgo de cambios. El nivel de visibilidad debe ser proporcional a la exposición y criticidad.

## Capítulo 13 — Riesgo de concentración y dependencia

La evaluación debe considerar si múltiples procesos críticos dependen de un mismo proveedor, región, plataforma, proveedor de modelos, servicio cloud o dependencia aguas arriba. La concentración puede quedar oculta cuando distintos proveedores comparten el mismo servicio subyacente.

## Capítulo 14 — Evidencia de resiliencia y recuperación

Para servicios críticos, la debida diligencia debe examinar capacidad de recuperación, supuestos de dependencia, evidencia de pruebas, objetivos de recuperación, procesos de comunicación y si existe una alternativa o ruta de salida viable.

## Capítulo 15 — Notificación y coordinación de incidentes

Los contratos y procedimientos operativos deben establecer cómo se notifican los incidentes materiales del proveedor, qué información se espera, quién recibe la notificación y cómo se coordinan la contención, investigación, recuperación y comunicaciones regulatorias o con clientes.



## Capítulo 16 — Paquete de aprobación

El paquete de aprobación debe resumir alcance del servicio, criticidad, riesgo inherente, evidencia de debida diligencia, hallazgos materiales, tratamientos contractuales, excepciones abiertas, riesgo residual, nivel de monitoreo, consideraciones de salida y aprobación humana.

La aprobación debe corresponder al servicio y alcance efectivamente revisados.

## Capítulo 17 — Controles de incorporación

La incorporación debe verificar que los términos contractuales aprobados, límites de acceso, requisitos de tratamiento de datos, contactos de seguridad e incidentes, nivel de monitoreo y propiedad del servicio estén implementados antes del uso en producción.

## Capítulo 18 — Monitoreo continuo

El monitoreo debe enfocarse en indicadores vinculados con riesgo material: eventos de seguridad, degradación del servicio, dificultades financieras, cambios de propiedad, cambios de cumplimiento, cambios de subcontratistas, cambios de modelo o plataforma, hallazgos sin resolver y obligaciones contractuales.

## Capítulo 19 — Actualización de evidencia

La evidencia debe renovarse según el riesgo y su vencimiento. Informes independientes, certificaciones, políticas, evidencia de pruebas, seguros, documentos de privacidad y artefactos de resiliencia no deben seguir acreditándose indefinidamente una vez desactualizados.

## Capítulo 20 — Gestión de cambios

Los cambios materiales del proveedor deben activar un análisis de impacto. Ejemplos: nuevos subencargados, nuevas regiones de alojamiento, cambios de arquitectura, cambios en el uso de datos, fusiones, cambios del modelo de servicio, cambios de IA/modelo o cambios en compromisos de seguridad o privacidad.

## Capítulo 21 — Gobierno de hallazgos y remediación

Los hallazgos deben tener responsables, severidad, acciones, fechas, evidencia y escalamiento. Incumplimientos repetidos de fechas de remediación deben afectar el tratamiento del riesgo y pueden requerir restricciones del servicio, controles adicionales, aceptación ejecutiva o planificación de salida.

## Capítulo 22 — Gestión de excepciones

Las excepciones deben tener vigencia limitada y aprobación de la autoridad apropiada. El monitoreo debe verificar que los controles compensatorios sigan siendo eficaces y que las fechas de vencimiento no se eludan mediante renovaciones administrativas sin reevaluación.

## Capítulo 23 — Reevaluación periódica

La reevaluación debe considerar alcance actual del servicio, criticidad, uso de datos, evidencia de controles, incidentes, cambios del proveedor, desempeño, concentración, exposición a cuartas partes, estado contractual y preparación para la salida.

## Capítulo 24 — Decisión de renovación

La renovación debe ser una decisión de riesgo, no un evento automático de compras. El registro de aprobación debe identificar hallazgos sin resolver, cambios de exposición, evidencia vigente, riesgo residual y si deben cambiar los términos contractuales o el monitoreo.

## Capítulo 25 — Revisión de desempeño y riesgo del servicio

El desempeño operativo debe evaluarse junto con la evidencia de controles. Fallas persistentes del servicio, compromisos incumplidos, degradación del soporte o incidentes repetidos pueden cambiar el riesgo residual aun cuando los documentos formales de aseguramiento sigan vigentes.

## Capítulo 26 — Dependencia financiera y estratégica

Cuando sea material para la continuidad del servicio, la organización debe considerar viabilidad financiera, cambios de propiedad, riesgo de adquisición, dependencia estratégica y factibilidad de reemplazar al proveedor.

Estas consideraciones deben manejarse de manera proporcional y con aporte de especialistas apropiados.

## Capítulo 27 — Devolución y eliminación de datos

La planificación de salida debe definir qué datos, configuraciones, registros, artefactos, modelos, prompts u otra información deben devolverse, transferirse, conservarse o eliminarse. La finalización debe contar con evidencia cuando existan requisitos contractuales o regulatorios.

## Capítulo 28 — Terminación de accesos

La salida debe revocar cuentas, credenciales, claves de API, acceso de red, acceso privilegiado, acceso de soporte, integraciones, certificados y otras conexiones del proveedor que ya no sean necesarias.

## Capítulo 29 — Transición y continuidad

Los proveedores críticos deben contar con un plan de transición realista que considere servicios sustitutos, migración de datos, dependencias técnicas, transferencia de conocimiento, tiempos y controles interinos.

Un plan de salida que no pueda ejecutarse dentro de las tolerancias del negocio debe tratarse como un riesgo actual.

## Capítulo 30 — Obligaciones residuales

Después de terminar el servicio, algunas obligaciones pueden continuar, incluidas confidencialidad, retención de registros, eliminación de datos, cooperación ante incidentes, soporte de auditoría, términos de propiedad intelectual o retenciones legales. Deben rastrearse hasta su cierre.

## Capítulo 31 — Limitaciones del aseguramiento TPRM

Un proceso TPRM controlado reduce incertidumbre, pero no puede certificar que un proveedor esté libre de riesgo. Las conclusiones deben identificar evidencia, alcance, periodo, supuestos y limitaciones de las que dependen.

## Capítulo 32 — Límite de publicación del manual

Antes de publicar este manual deben completarse la verificación de fuentes, el maestro controlado en inglés, la revisión multidisciplinaria, la revisión semántica es-419 y pt-BR, la revisión de gráficos/accesibilidad, QA documental y por página, procedencia, auditoría de seguridad del repositorio y la Aprobación Humana Final de Publicación.

Los cambios materiales posteriores a una aprobación humana reabren las puertas afectadas.